

Compliance Frameworks in Cloud Computing (ISO, GDPR, HIPAA)

➤ Compliance Framework :

Compliance frameworks are standards and regulations that ensure security, privacy, and proper handling of data in cloud computing environments.

They help organizations:

- Protect sensitive data
- Follow legal requirements
- Maintain user privacy
- Ensure cloud security

+

➤ ISO Compliance :

ISO stands for International Organization for Standardization.

Common ISO standards in cloud:

- ISO 27001 – Information Security
- ISO 27017 – Cloud Security
- ISO 27018 – Cloud Privacy

Main Goal of ISO 27001

- Protect data confidentiality
- Maintain data integrity
- Ensure data availability

ISO focuses on:

1. Risk Assessment

The company identifies:

- Data risks
- Security threats

- **Example:**

Unauthorized employee access risk

2. Access Control

Only authorized users can access data.

Example:

- Admin access is separate
- Employee access is limited
- Guest access is restricted

3. Data Encryption

Data is stored in a secure format.

Example:

Passwords stored in encrypted database

5. Security Policies

The company defines security rules.

Example:

- Strong password policy
- Multi-factor authentication
- Session timeout

Real Cloud Example (AWS Based)

Suppose a banking application uses AWS cloud.

The bank stores:

- Customer account data
- Transaction history
- Personal details

ISO 27001 ensures:

- Data is encrypted (AWS encryption)
- Only authorized employees can access data
- Activity logs are maintained
- Regular backups are taken
- Multi-factor authentication is enabled

Why ISO 27001 is Important in Cloud

- Prevents data breaches
- Improves cloud security
- Builds customer trust
- Helps in compliance
- Reduces security risks

➤ **GDPR : General Data Protection Regulation**

What is GDPR?

GDPR is a data privacy law of the European Union (EU) that protects personal data of users.

It tells companies how to collect, store, and use user data safely.

Main Goals of GDPR

- Protect user privacy
- Give control to users
- Prevent data misuse
- Ensure transparency

Key Principles of GDPR

1. User Consent

The company must ask permission before collecting data.

Example: Checkbox → "I agree to privacy policy"

2. Right to Access

User can view stored data.

Example: Download my data option

3. Right to Delete (Right to be Forgotten)

- User can delete their data.
- **Example:** Delete account button

4. . Data Breach Notification

If data leaks, users must be notified.

Example:

Email: "Your data may have been exposed"

Real Example

Google account:

User can:

- **Delete account**
- **Download data**
- **Control privacy settings**

This follows GDPR rules.

➤ **HIPAA -Health Insurance Portability and Accountability Act**

What is HIPAA?

HIPAA is a US healthcare data protection law that protects patient medical information. It ensures that health data is secure and only authorized people can access it.

Main Goal of HIPAA

- Protect patient data
- Maintain medical privacy
- Prevent unauthorized access
- Secure healthcare systems

Key Rules of HIPAA

1. Access Control

Only authorized people can access patient data.

Example:

Doctor can view reports

Receptionist cannot view medical history

2. Data Encryption

Medical data must be encrypted.

Example:

Patient records stored securely in cloud

3. Audit Logs

System tracks who accessed data.

Example: Doctor viewed patient record at 10 AM

5. Backup and Recovery

Data can be restored after loss.

Example:

Cloud backup of hospital database

Real Cloud Example

Hospital stores in cloud:

- Patient reports
- Medical history
- Lab results

HIPAA ensures:

- Only authorized doctors access data
- Data encrypted
- Logs maintained
- Backup available

ISO vs GDPR vs HIPAA (Comparison)

Feature	ISO	GDPR	HIPAA
Type	Standard	Law	Law
Focus	Security	Privacy	Healthcare data
Region	Global	Europe	USA
Use	Cloud security	User data protection	Medical data
Example	AWS security	Google privacy	Hospital cloud

➤ Advantages of Compliance Frameworks

- Improves data security
- Protects user privacy
- Ensures legal compliance
- Increases customer trust
- Better risk management

- Reduces data breaches
- Provides standardized policies
- Enhances cloud security

➤ Disadvantages of Compliance Frameworks

- Expensive implementation
- Time-consuming process
- Requires extensive documentation
- Complex to implement
- Continuous monitoring required
- May slow down operations
- Requires staff training
- Difficult for small organizations